Equipo: Fun Gang

Integrantes: Marcial Ibañez, Luis Pino, Martín Gottschalk

Profesor: Ayrton Cortes

AREGAR:

-Auditoría -> log de acciones del usuario.

-No repudio -> (checkbox, almacenar en la BDD).

-TOS: Términos y Condiciones. Crearlo y agregarlo como parte del sistema. Como sistema bancario, hay puntos importantes (ej: borrar la cuenta, el usuario tiene q tener $0 en la cuenta).

-logs: toma de accion precisa, canal, dispositivo

Indice

Caso 4 Billetera digital: Monify **2**
ACTIVIDAD 1 ..... **3**
1. Mapeo de actores y datos 3
2. Identificación de riesgos CIA 3
Actividad 2 - Cifrado 6
Parte 1 y 2 : Minimización, seudonimizacion y anonimización **9**
Modelo base de datos 9
Decisiones de minimización por tabla 10
Nuevo diseño de la base de datos 21
Parte 3: Role-Based Access Control **23**
Parte 4 ..... **24**
Evidencias: 24
ACTIVIDAD 5: Gestión del consentimiento **26**
Parte 1. Implementación del módulo de gestión del consentimiento 26
Parte 2. Implementación de funcionalidades para el ejercicio de derechos 27
Parte 3. Implementación del registro de auditoría 28
Parte 4. Elaboración del plan de respuesta a incidentes de seguridad 30
Parte 5. Evidencias 32

Caso 4 Billetera digital: Monify

Contexto: Monify es una billetera digital chilena que permite a sus usuarios recibir, enviar y guardar dinero, además de solicitar líneas de crédito de consumo. Para operar, exige verificar la identidad de cada usuario (KYC, por sus siglas en inglés) y evalúa su riesgo de crédito antes de aprobar cualquier línea.

Descripción del sistema: El grupo debe diseñar la plataforma que gestiona: cuentas de usuario, transferencias, historial de transacciones, verificación de identidad, solicitud y evaluación de créditos, y el cálculo de un puntaje (score) de comportamiento financiero.

Actores del sistema:

• Usuario, titular de la cuenta y de la billetera digital.

• Administrador de riesgo, que evalúa las solicitudes de crédito.

• Entidad verificadora de identidad, como tercero que valida el KYC.

• Central de riesgo o buró de crédito, como tercero que informa el historial financiero.

ACTIVIDAD 1

1. Mapeo de actores y datos

En equipo, identifiquen quién interactúa con su sistema (cliente, administrador, un tercero como una pasarela de pago) y qué dato genera o consulta cada uno.

2. Identificación de riesgos CIA

Para cada flujo de datos que anotaron, decidan qué atributo del triángulo CIA (confidencialidad, integridad o disponibilidad) está más en riesgo, y por qué.

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
Usuario	Rut	Confidencialidad	Esta información puede vulnerar la privacidad del usuario (facilitar acceso a datos sensibles). Por lo que debe ser protegida.
Usuario	Renta Mensual	Confidencialidad	Esta información revela la capacidad económica mensual del usuario, toda la información bancaria es privada según la nueva ley, además de que si se filtra, puede ser usado para hacer a algún daño al cliente
Usuario	Renta Mensual	Integridad	Se necesita mantener actualizada la renta con el fin de realizar una correcta evaluación de crédito
Usuario	Historial de transacciones	Disponibilidad	El historial siempre tiene que estar disponible para cuando el usuario lo necesite, porque necesita
Usuario	Historial de transacciones	Integridad	La información tiene que ser siempre constante (transacciones no cambian). Además, la información de fechas debe ser correcta (no atrasarse).

Usuario	Ultima cotizacion	Confidencialidad	Las cotizaciones contienen varios tipos de información personal, tanto información identificable como información bancaria e incluso la dirección
Usuario	Morosidad	Confidencialidad	Esta información puede ser usada para extorsionar o amenazar a una persona
Usuario	Tiempo en morosidad	Integridad	De no actualizarse y mantenerse al día, este dato podría indicar que una persona es más morosa de lo que en realidad es, lo que afectará negativamente a su puntaje crediticio
Usuario	Tiempo en morosidad	Confidencialidad	Esta información puede ser usada para extorsionar o amenazar a una persona
Usuario	Cantidad de deuda	Integridad	La deuda siempre debe ser igual, sin importar desde qué sistema se vea. Importante que no se altere sin control del Usuario.
Usuario	Tiempo en deuda	Confidencialidad	Información sensible, pues puede ser motivo de discriminacion.
Usuario	Tiempo en deuda	Integridad	El tiempo debe ser preciso y real según la información real. No debe modificarse al azar, pues este dato es un factor de decisión en la toma de decisiones del usuario.
Usuario	Créditos activos	Confidencialidad	Revela información financiera sensible de una persona o entidad. Si es accedido por personas no autorizadas, puede usarse para fraude o suplantación de identidad
Usuario	Huella dactilar	Confidencialidad	Esta información puede vulnerar la privacidad del usuario (facilitar acceso a datos sensibles). Por lo que debe ser protegida.

Usuario	Clave digital	Confidencialidad	Esta información puede vulnerar la privacidad del usuario (facilitar acceso a datos sensibles). Por lo que debe ser protegida.
Usuario	Nombre	Confidencialidad	Su exposición no autorizada, especialmente combinada con otros datos (dirección, RUT, información financiera, etc.), puede facilitar la suplantación de identidad
Usuario	Cartola fondo inversiones	Integridad	Refleja el estado real de las inversiones de una persona o entidad . Si sus valores son alterados podría llevar a decisiones erróneas
Admin. De Riesgo	Agenda de Contactos	Integridad	Podría provocar pérdida de contacto con clientes o proveedores importantes e incluso interrupciones operativas
Admin. De Riesgo	Metrica de riesgo	Integridad	Podría llevar a aprobar créditos o inversiones que en realidad son de alto riesgo, o rechazar operaciones que eran viables. Lo que puede en el peor caso llevar a la quiebra
Usuario	Creditos	Confidencialidad	Expone información financiera sensible sobre los montos solicitados, condiciones pactadas y situación de endeudamiento.
Central de Riesgo	Score comportamiento financiero	Integridad	Puede alterar de forma directa las decisiones de otorgamiento de crédito, tasas de interés o condiciones comerciales ofrecidas.

Actividad 2 - Cifrado

El algoritmo AES 256 es el más usado en datos bancarios y financieros fue establecido por el Instituto Nacional de Estándares y Tecnología (NIST)

Campo	Tecnica (cifrado, hashing, tokens)	Justificación	Algoritmo / Libreria	Ubicación donde se protege (reposo, tránsito, en uso)	Observaciones de gestiones de llaves
Rut	Cifrado	Como dato personal identificador, corresponde a un requisito legal y protege la integridad del paciente.	AES-256	En reposo y en tránsito	Cifrado hibrido
Renta Mensual	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Como phishing dirigido o desvios de pago	AES-256	En reposo, en tránsito en uso	Cifrado Simetrico
Historial de transacciones	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Puede ser usado para perfilamiento.	AES-256	En reposo, en tránsito, en uso	Cifrado Simetrico
Ultima cotizacion	Cifrado	Se pueden extraer rutas, direcciones, información de facturación y demás información sensible e identificable. Puede ser usado para perfilamiento y robo de dinero	AES-256	En reposo, en tránsito, en uso	Cifrado Asimetrico
Morosidad	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Puede usar usada para perfilamiento y chantaje	AES-256	En reposo y en tránsito	Cifrado Asimetrico
Tiempo en morosidad	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Puede usar usada para perfilamiento y chantaje	AES-256	En reposo y en tránsito	Cifrado Asimetrico

Cantidad de deuda	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Puede ser usada para chantaje o Suplantación de cobranza legítima	AES-256	En reposo y en tránsito	Cifrado Asimetrico
Tiempo en deuda	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Puede ser usada para chantaje o Suplantación de cobranza legítima	AES-256	En reposo y en tránsito	Cifrado Asimetrico
Créditos activos	Cifrado	Es un dato personal y sensible, corresponde a información bancaria y crediticia que puede ser usada con fines maliciosos. Estafas de sobreendeudamiento, chantaje o Suplantación de cobranza ilegítima	AES-256	En reposo y en tránsito	Cifrado Asimetrico
Huella dactilar	Hashing	Puede ser usado como contraseña o llave de ingreso a los sistemas.	bcrypt	Transito	Sin llave por su formato unidireccional. Se usara salting para cada hash.
Clave digital	Hashing	Es una contraseña (de la tarjeta), por lo que requiere hashing.	bcrypt	Transito	Sin llave por su formato unidireccional. Se usará salting para cada hash.
Nombre	Cifrado	Como dato personal identificador, corresponde a un requisito legal y protege la integridad del paciente.	AES-256	En reposo y en tránsito	Cifrado Simetrico
Cartola fondo inversiones	Cifrado	Revela patrimonio disponible, no solo ingresos o deudas. Fraude, extorsión, ingeniería, social, etc.	AES-256	En reposo y en tránsito	Cifrado Asimetrico
Agenda de Contactos	Cifrado	Es una colección de medios para contactar a los clientes. Si se filtra, puede usarse para tratar de estafar a los clientes en nombre de la empresa legítima.	AES-256	En reposo	Cifrado Asimetrico
Metrica de riesgo	Cifrado	Es un dato construido en base a información crediticia y bancaria, por lo que puede ayudar a perfilamiento económico	AES-256	En reposo	Cifrado Asimetrico

Creditos	Cifrado	Los créditos en si no son sensibles, pero los créditos que un usuario tiene a su nombre si lo son y pueden usarse para perfilamiento y manipulación	AES-256	En reposo	Cifrado Asimetrico
Contraseña de acceso virtual	Hashing	Es la contraseña de acceso a la plataforma, por lo que requiere la mayour protección ante ataques de fuerza-bruta	bcrypt	En uso, Reposo, Tránsito.	Sin llave por su formato unidireccional. Se usará salting para cada hash.
Sesión en la plataforma.	Tokens	Para conceder acceso temporal al sistema.	JWT	En uso, Transito.	Sin llave por su formato unidireccional.
Logs de acciones (en la plataforma)	Cifrado	La información de las acciones puede contener información sensible, puede incluir tiempos de uso, usuario, acciones tomadas, lo cual puede ser usado para ingeniería social.	AES-256	En reposo, tránsito, en Uso.	Cifrado simetrico

Bibliografia:

- Congreso Nacional de Chile. (01 de diciembre de 2026). Ley no. 21.719. *Regula la Protección y el Tratamiento de los Datos Personales y Crea la Agencia de Protección de Datos Personales*. 13 de diciembre de 2024. https://bcn.cl/GapReB
- Congreso Nacional de Chile. (09 de mayo de 2023). Ley no. 19.628. *Sobre Protección de la Vida Privada*. 28 de agosto de 1999. https://bcn.cl/2eqfn

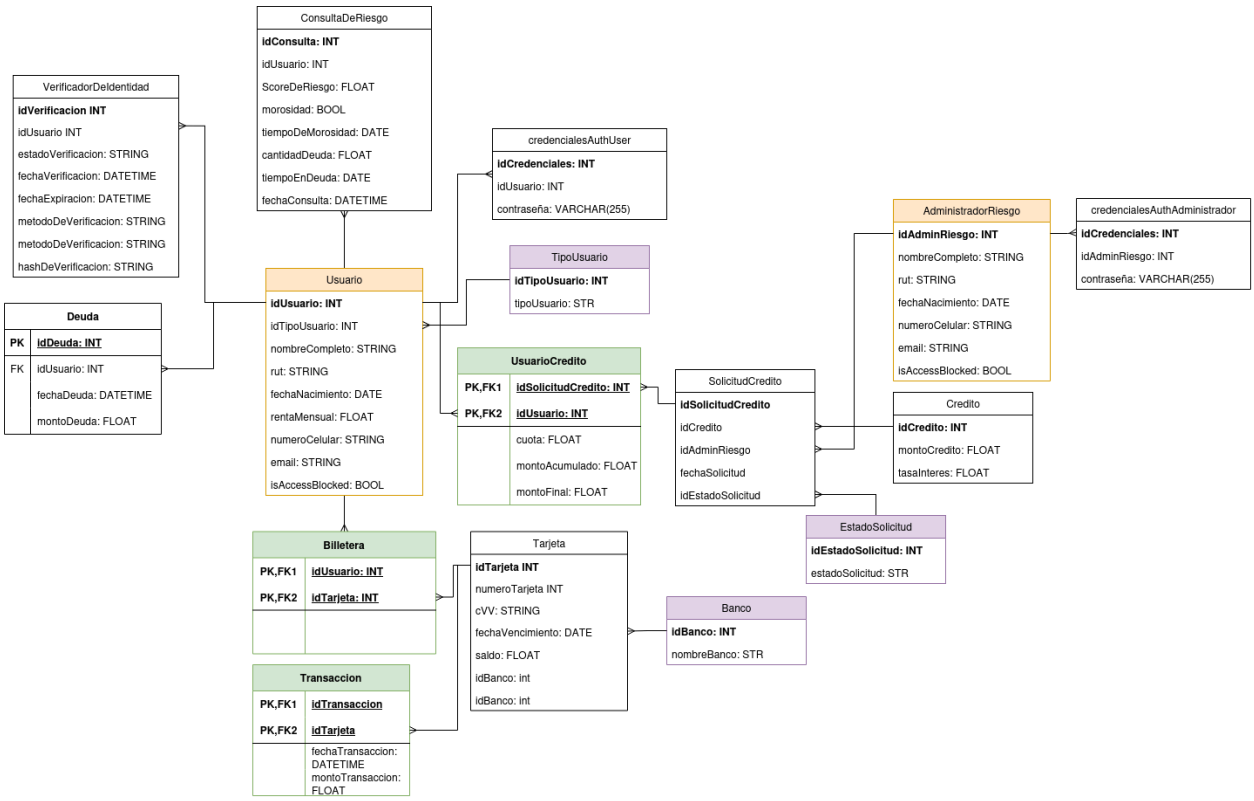
3 estados de Cifrado: https://www.sealpath.com/es/blog/tres_estados_info/

Sha-256 vs bcrypt: https://compile7.org/compare-hashing-algorithms/what-is-difference-between-sha-256-vs-bcrypt/#purpose-and-design-focus

ACTIVIDAD 4

Parte 1 y 2 : Minimización, seudonimizacion y anonimización

Modelo base de datos





Decisiones de minimización por tabla

Usuario

Campo	**Desición**	**Justificación**
idUsuario	Conservar	Se necesita para indexado y diferenciación
idTipoUsuario	Conservar	Se necesita para indexado, diferenciación y para mantener la entidad relacional
nombreCompleto	Reemplazo por pseudónimo -> palabras aleatorias o acronimos	No es necesario almacenar el nombre completo en su totalidad
Rut	Reemplazo por pseudónimo -> número sin conexión al rut (tipo ID)	Para que no se atribuya el dato a una persona específica.
fechaNacimiento	Reemplazar por indicador de mayoría de edad (“esMayorDeEdad: BOOL”)	Solo se necesita verificar que el usuario puede contratar productos financieros legalmente. La fecha puede provocar perfilamiento y la suplantación de identidad.
RentaMensual	Reemplazar por tramo de renta (“RangoRentaMensual: STR”)	La evaluación de crédito solo requiere la capacidad de pago aproximada, no el monto exacto del ingreso.
numeroCelular	Reemplazo por pseudónimo -> palabras aleatorias o numero sin relacion	Para que no se atribuya el dato a una persona específica.
email	Reemplazo por pseudónimo -> palabras aleatorias o numero sin relacion	Para que no se atribuya el dato a una persona específica.
isAccessBlocked	Conservar	Es esencial para marcar la cuenta cuando pasa el total de

		intentos permitidos.

CredAuthUser

Campo	**Desición**	**Justificación**
idCredenciales	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y entidad relacional
contraseña	Almacenar sólo el hash	Nunca se guarda en texto plano. El hash permite validar el acceso sin poder recuperar la clave original.

UserLogs:

Campo	**Desición**	**Justificación**
uniqueID	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y para mantener la entidad relacional
fechaAccion	Conservar	Se necesita mantener para mantener un log confiable
sistema	Conservar	Se necesita mantener para mantener un log confiable
accion	Conservar	Se necesita mantener para mantener un log confiable
dispositivo (canal)	Conservar	Se necesita mantener para mantener un log confiable

ConsultaDeRiesgo

Campo	**Desición**	**Justificación**
idConsulta	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
scoreDeRiesgo	Conservar	Se necesita para realizar la evaluación, y sin conocer específicamente las reglas de negocio no puede ser usado para perfilamiento
morosidad	Conservar	Es un indicador booleano, de por sí, debe protegerse mediante cifrado más que por minimización.
tiempoDeMorosidad	Reemplazar por tramos (“tiempoDeMorosidad: STR”)	Se puede generalizar la gravedad de la mora y no perder información en el proceso
cantidadDeDeuda	Eliminar	Es un dato calculable y altamente sensible, por lo que se elimina de los registros.
tiempoEnDeuda	Reemplazar por tramos (“tiempoEnDeuda: STR”)	Se puede generalizar y no perder información en el proceso
fechaConsulta	Conservar	Permite validar la vigencia del score y la auditoría



VerificadorDeIdentidad

Campo	**Desición**	**Justificación**
idVerificacion	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
estadoVerificacion	Conservar	No representa un dato sensible o personal
fechaVerificacion	Conservar	No representa un dato personal o sensible
fechaExpiracion	Conservar	No representa un dato personal o sensible
metodoDeVerificacion	Conservar	No representa un dato personal o sensible
hashDeVerificacion	Almacenar sólo el hash	Nunca se guarda en texto plano. El hash permite validar el acceso sin poder recuperar la clave original.

TipoUsuario

Campo	**Desición**	**Justificación**
idTipoUsuario	Conservar	Se necesita para indexado y diferenciación
tipoUsuario	Seudonomizar ->Tu	A pesar de que es un dato general, si puede aportar al perfilamiento y obtener información adicional no necesaria.



Deuda

Campo	**Desición**	**Justificación**
idDeuda	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
fechaDeuda	Conservar	Se necesita exactitud para el cálculo de riesgo. Se compensará la exposición con un cifrado robusto
montoDeuda	Conservar	Compensar la exposición con un cifrado robusto

UserConsent

Campo	**Desición**	**Justificación**
idConsent	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
finalidad	Conservar	La ley exige que la finalidad sea específica y exacta
versionTexto	Conservar	No representa un dato personal ni sensible
canal	Conservar	La ley exige demostrar los canales de consentimiento
otorgado_el	Conservar	Es necesario mantener la precisión del dato por razones de registro de consentimiento
revocado_el	Conservar	Es necesario mantener la precisión del dato por razones de registro de revocación de

		consentimiento.

Billetera

Campo	**Desición**	**Justificación**
idUsuario	Conservar	Se necesita para indexado y diferenciación
idTarjeta	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional

Transaccion

Campo	**Desición**	**Justificación**
idTransaccion	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
fechaTransaccion	Conservar	Debe mantenerse exacta para mantener la integridad del historial. Es base para auditoría y no repudio.
montoTransaccion	Conservar	Es necesario para mantener la integridad del historial. Se compensa la exposición con un cifrado robusto.



Tarjeta

Campo	**Desición**	**Justificación**
idTarjeta	Conservar	Se necesita para indexado y diferenciación
idBanco	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
numeroTarjeta	Conservar	Se necesita identificar la tarjeta. Se compensará con cifrado robusto
CVV	Eliminar	No es necesario el almacenamiento ya momento de realizar transacciones con tarjetas, el usuario es solicitado a ingresar el CVV, el cual es verificado por un tercero para validar la transacción
fechaVencimiento	Eliminar	No es necesario revisar la fecha de vencimiento, nosotros no manejamos las tarjetas, pues proveen de un tercero (el cual rechaza la transacción si está vencida).
saldo	Conservar	Se necesita exactitud de montos y pagos. Se compensa con un alto cifrado



Banco

Campo	**Desición**	**Justificación**
idBanco	Conservar	Se necesita para indexado y diferenciación
nombreBanco	Conservar	No es un dato sensible ni personal

UsuarioCredito

Campo	**Desición**	**Justificación**
idSolicitudCredito	Conservar	Se necesita para indexado y diferenciación
idUsuario	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
cuota	Conservar	Es necesario mantenerlo exacto para el cobro
montoAcumulado	Conservar	Es necesario para conocer el avance en los pagos y para el cálculo de riesgo
montoFinal	Conservar	Es necesario para trasparencia con el cliente y con



SolicitudCredito

Campo	**Desición**	**Justificación**
idSolicitudCredito	Conservar	Se necesita para indexado y diferenciación
idAdminRiesgo	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
idCredito	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
idEstadoSolicitud	Conservar	Se necesita para indexado, diferenciación y mantener la entidad relacional
fechaSolicitud	Conservar	Se necesita para la trazabilidad

EstadoSolicitud

Campo	**Desición**	**Justificación**
idEstadoSolicitud	Conservar	Se necesita para indexado y diferenciación
estadoSolicitud	Conservar	No es un dato personal ni sensible



Credito

Campo	**Desición**	**Justificación**
idCredito	Conservar	Se necesita para indexado y diferenciación
montoCredito	Conservar	Es condición intrínseca del producto, por sí solo no es dato personal ni sensible
tasaInteres	Conservar	Se conserva por transparencia y calculo de negocio

AdministradorRiesgo

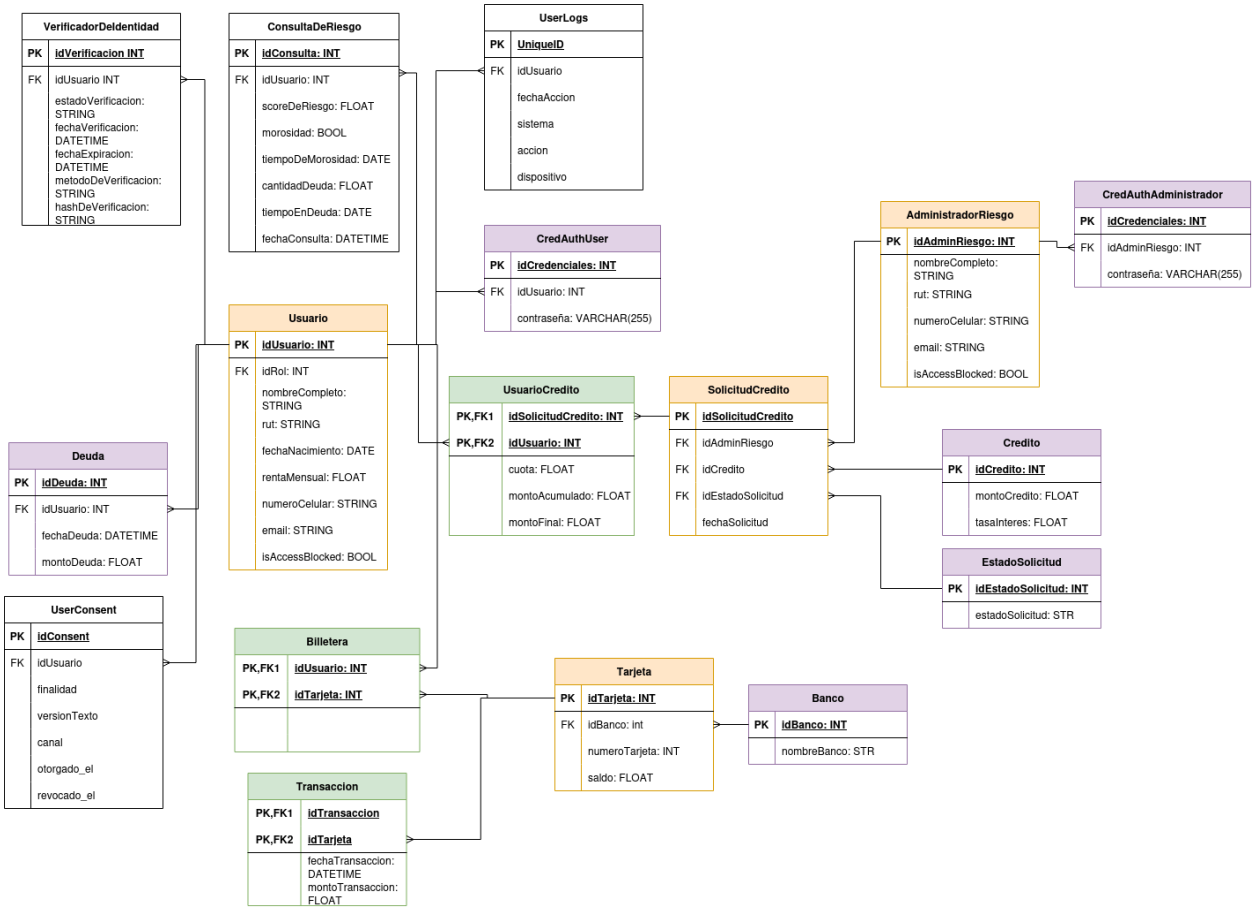
Campo	**Desición**	**Justificación**
idAdminRiesgo	Conservar	Se necesita para indexado y diferenciación
fechaNacimiento	Eliminar	No es un dato relevante a tener para que el administrador ejecute su tarea.
nombreCompleto	Reemplazo por pseudónimo -> palabras aleatorias o acronimos	Para que no se atribuya el dato a una persona específica.
rut	Reemplazo por pseudónimo -> número sin relación con el rut	Para que no se atribuya el dato a una persona específica.
numeroCelular	Reemplazo por pseudónimo -> palabras aleatorias o número sin relación	Para que no se atribuya el dato a una persona específica.
correo	Reemplazo por pseudónimo -> palabras aleatorias o número sin relación	Para que no se atribuya el dato a una persona específica.
isAccessBlocked	Conservar	Es un dato booleano, por lo

		que lo mejor que se puede hacer es ofuscar el nombre del identificador.

CredAuthAdministrador

Campo	**Desición**	**Justificación**
idCredenciales	Conservar	Se necesita para indexado y diferenciación
idAdminRiesgo	Conservar	Se necesita para indexado, diferenciación y entidad relacional
contraseña	Definir plazo de conservación de 24 horas.	Reduce las posibilidades de que la cuenta sea comprometida si se consigue acceso a la base o si alguien consigue acceso al dispositivo del administrador.

Nuevo diseño de la base de datos



Parte 1: Explicar cómo el nuevo diseño contribuye a la minimización de datos y a la protección de la privacidad.

El nuevo diseño aplica los cambios mencionados en las tablas, llevando a la minimización de datos personales. Las principales tablas afectadas fueron Tarjeta, Usuario y ConsultaDeRiesgo, esto debido a que concentran la información sensible de los clientes. También se removieron datos que consideramos innecesarios para el funcionamiento del sistema. Esto con el fin de reducir el nivel de exposición al que se someten nuestros clientes al usar nuestro sistema, entregando más confianza y reduciendo el daño (no eliminando) que podría ocasionarse en caso de existir alguna vulneración de seguridad.

Parte 2: Describir cómo se evitará exponer datos personales en registros de actividad, reportes, pruebas o ambientes de desarrollo, cuando corresponda.

Además de los cambios dentro del diseño a nivel de esquema, también se aplicaron las siguientes medidas de seguridad para evitar exponer datos personales:

- Seudoanonimizacion: Se aplicará a los datos personales sensibles que identifican directamente al cliente (como su nombre o el rut) esto con el fin de dificultar el perfilamiento de los clientes mediante los datos almacenados. Aunque por temas legislativos financieros se guardará un método para regresar a los datos originales de manera separada a la base de datos, esto para evitar que se filtre todo a la vez en caso de vulnerabilidad.
- Cifrado: Este funciona como medida de seguridad principal en caso de que se filtren los datos que se encuentran en la base de datos. Con él los datos serán inentendibles al estar protegidos por las llaves de cifrado y algoritmos robustos, evitando que puedan leerse los datos como texto plano y reduciendo el daño causado por las posibles vulnerabilidades.
- Ambiente Dev / Prod: cada ambiente cuenta con una base de datos separada. La del entorno de desarrollo será llenada con datos aleatorios, no reales. Mientras que la usada en producción es la mantenida con los datos genuinos de nuestros usuarios y sistemas. Las medidas de seguridad se aplican en ambos entornos, ya que la exposición de uno podría llevar a revelar detalles del otro.
- Reportes: para cumplir con el principio de portabilidad de los datos, permitiremos a los usuarios la descarga de todos los datos que le pertenecen (cuenta, transacciones, tarjetas). No puede acceder a esta información sin pasar

Parte 3: Role-Based Access Control

El sistema de billetera Monify cuenta con 5 roles internos:

1. Admin: administra y gestiona elementos de la funcionalidad del sistema. Los roles, bitácora de acciones realizadas y creación de cuentas.
2. Usuario: es quien usa el sistema para manejar sus propias tarjetas y enviar o recibir transferencias. Puede postular a créditos.
3. Administrador de riesgo: maneja, vigila y evalúa los resultados de los motores de riesgo, así como evaluar los casos particulares.
4. Auditor: se encarga de analizar el registro de logs y otras medidas de seguridad para asegurar la integridad, confidencialidad y disponibilidad de los datos.
5. Operador financiero: se encarga de gestionar las solicitudes de crédito y aprobarlas según la información del usuario solicitante.

Monify no contiene los usuarios de Entidad verificadora de identidad, o Central de riesgo o buró de crédito, ya que provienen de terceros. Adelante, se muestran las acciones o recurso según el rol:

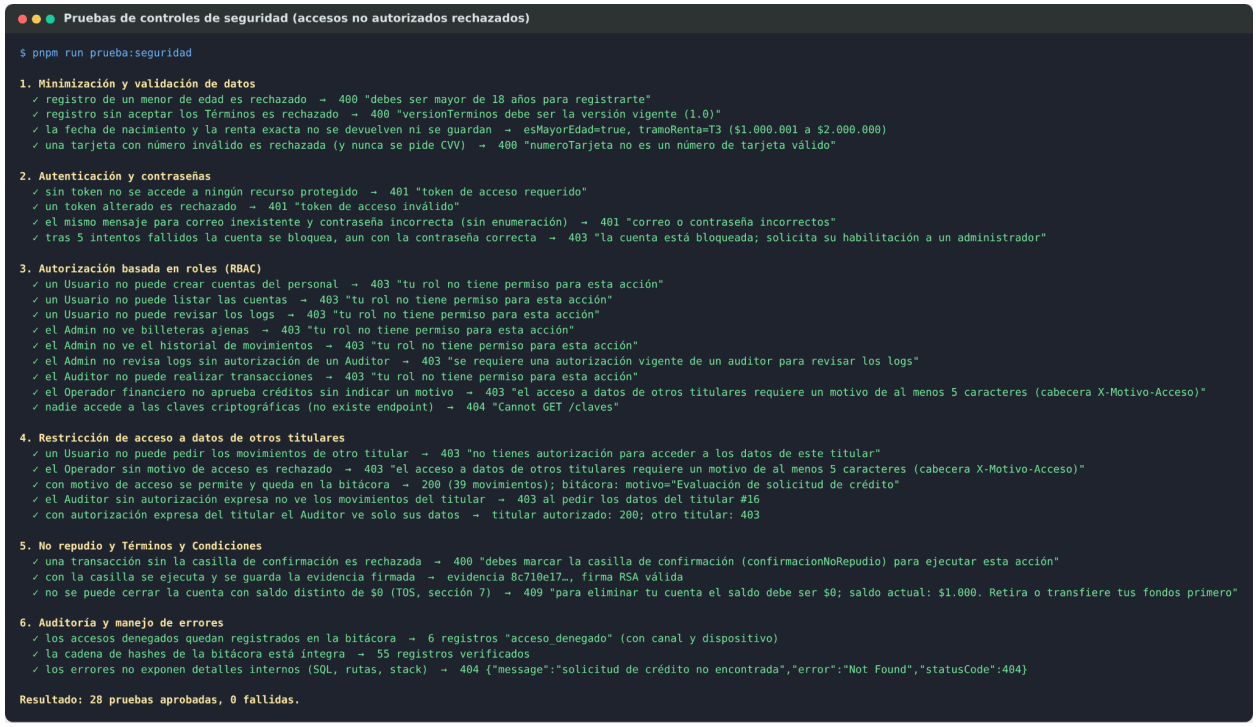
Acción o Recurso / Rol	**Admin**	**Usuario**	**AdministradorDe Riesgo**	**Auditor**	**OperadorFinanciero**
Ver información financiera	Denegado	Solo propia	Permitido, según necesidad	De otros, Solo con autorización expresa	De otros, Solo con autorización expresa
Actualizar/ Modificar perfil	Permitido	Solo el propio	Denegado	Denegado	Denegado
Ver billetera	Denegado	Solo propia	Denegado	Denegado	Denegado
Ver historial de movimientos financieros	Denegado	Solo el propio	Permitido	De otros, Solo con autorización expresa	Permitido de otros, según necesidad
Ver deuda	Denegado	Solo propia	Permitido		Permitido de otros, según necesidad
Realizar transaccion	Denegado	Permitido	Denegado	Denegada	Denegado

Crear solicitud de crédito	Denegado	Permitido	Denegado	Denegado	Denegado
Aprobar solicitud de crédito	Denegado	Denegado	Permitido	Denegado	Permitido, según necesidad
Gestionar roles y permisos	Permitido	Denegado	Denegado	Denegado	Denegado
Acceso a claves criptográficas	Denegada	Denegada	Denegada	Denegada	Denegada
Crear cuentas	Permitido	Denegada	Denegada	Denegada	Denegada
Revisar Logs del Sistema	Segun autorizacion	Denegada	Denegada	Denegada	Denegada

Parte 4

Evidencias:

Pruebas de seguridad:



Campos cifrados:

Campos sensibles cifrados: tarjeta y saldo con AES-256-GCM (v1), riesgo con RSA-OAEP (va1)

```
$ psql -c 'SELECT … FROM "Tarjeta"; SELECT … FROM "ConsultaDeRiesgo"'
 idTarjeta |              numeroTarjeta               |                  saldo
-----------+------------------------------------------+----------------------------------------
        11 | v1.97oGIi5W6ivwo+Qj.vpFz4Nd0MtgzBAOatfbg… | v1.VmBzrG7wIYUGIiRh.PISXFxMJU2q2+nfkbFQN…
         1 | v1.RQdW9kNRIxvLWchG.ghsx+8xVCu2zgxC6I3vD… | v1.BEc+mhTiTCGn5amK./1bo5F3IeHVMIP94g7lG…
         2 | v1.XdJqmx3PX3KAX+BU.ZJPND/uB+jvCozCkl3Up… | v1.pfv+23GUtsEGIY6J.w2oiZOsBxW4+qcj0Fiec…
        12 | v1.dj4yc7AfYLhX5I+d.5IJADtCoYBUyvWkCMewr… | v1.Jq8lHIlqQU6MFEIM.Ege0n17xsAB8/R8c1PrF…
(4 rows)

 idConsulta |             score              |            morosidad             |            tramoMora
------------+--------------------------------+----------------------------------+---------------------------------
          1 | va1.G5k9S/5zmABJoKZrmHbH4TLvfv… | va1.kZPrDVVNndGZbo4UD/Z0zZ7cQM… | va1.TCpKae2EqmmVdSrlOOyaB1FKuz…
          2 | va1.Me/EG2ZwhCVmyhIAJTpn8E5juw… | va1.sBoIA5ejFYX0rj6cWuwwKaWPkd… | va1.CZiFZ7OIZgNMpChJ0+K7b3FAj/…
          3 | va1.Ne8lFYY1VIyw5o0h0OFKz/x3Nq… | va1.d2mE/1pTFAOjoJ9hOBHsEnUv/X… | va1.LTYCrHccGHB+6zHT6qDIEiCqOM…
(3 rows)
```

Restricciones BDD:

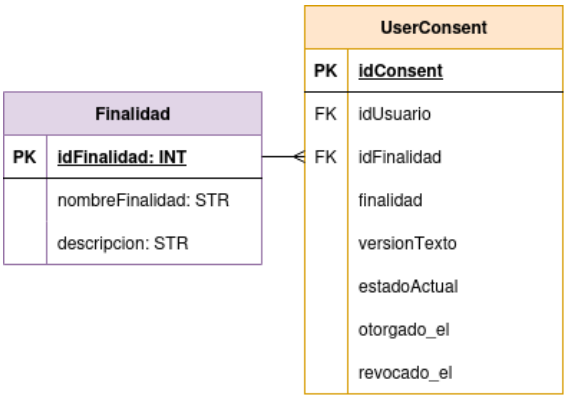
Restricciones en la base de datos: bitácora y evidencias de solo anexado, CHECK de ámbitos

```
$ psql -c 'UPDATE "UserLogs" …; DELETE FROM "EvidenciaNoRepudio"; INSERT … ambito=''claves'''
ERROR:  La tabla UserLogs es de solo anexado (auditoría y no repudio): no admite UPDATE ni DELETE
CONTEXT:  PL/pgSQL function fn_registro_inmutable() line 3 at RAISE
ERROR:  La tabla EvidenciaNoRepudio es de solo anexado (auditoría y no repudio): no admite UPDATE ni DELETE
CONTEXT:  PL/pgSQL function fn_registro_inmutable() line 3 at RAISE
ERROR:  new row for relation "AutorizacionAcceso" violates check constraint "AutorizacionAcceso_ambito_check"
DETAIL:  Failing row contains (3, 5, 6, null, claves, 2026-10-25 23:26:50.198424+00, 2026-10-25 23:26:50.198424+00, null).
```

ACTIVIDAD 5: Gestión del consentimiento

Parte 1. Implementación del módulo de gestión del consentimiento

Nuestro sistema ya contemplaba la implementación de registro del consentimiento. Sin embargo, nos faltaron detalles dentro de lo que era el almacenamiento apropiado de la finalidad. Adelante, están las nuevas tablas para cumplir con esta funcionalidad:



Como el cliente y las acciones que realiza dentro del sistema, en su mayoría, deben adherirse a procesos legales, los cuales están interconectados entre sí, por lo que tiene que aceptar todas las finalidades, de esta manera no asumimos que el consentimiento de una finalidad implica que otorga otra. El sistema no usa la información para obtener valor agregado o hacer publicidad, se enfoca completamente en la realización de funciones de la billetera digital.

Todas las finalidades se tienen que aceptar individualmente, y no se puede dejar ninguna fuera. Si no se entrega o se revoca el consentimiento a una de las finalidades a las que se le entregará al dato, implicaría con una denegación de acceso al sistema (a excepción del módulo para ejercitar los derechos del titular). El usuario no podra tomar acciones o visualizar información. Se quedará en una ventana pasado el inicio de sesión, que le pedirá dar el consentimiento y si lo rechaza se cierra la sesión.

Para mantener la trazabilidad de cambios, se creo un log (revisar la Parte 3).

Parte 2. Implementación de funcionalidades para el ejercicio de derechos

Desarrollen funcionalidades que permitan a los titulares solicitar el ejercicio de sus derechos sobre los datos personales tratados por el sistema.

Como mínimo, deberán implementar los siguientes mecanismos:

a. Acceso y portabilidad

- Permitir que el usuario solicite una copia de sus datos personales.
- Definir un formato de exportación adecuado, estructurado y legible por medios automatizados cuando corresponda.
- Verificar la identidad del solicitante antes de entregar la información.
- Evitar que la exportación incluya datos personales de terceros o información interna que no corresponda entregar.

b. Rectificación

- Permitir que el usuario solicite la corrección de información inexacta o desactualizada.
- Implementar validaciones para asegurar que los datos modificados cumplan las reglas del sistema.
- Registrar la operación y conservar la trazabilidad necesaria del cambio.
- Definir cómo se gestionan los datos que deban actualizarse en otros módulos o procesos relacionados.

c. Supresión

- Permitir que el titular solicite la eliminación de sus datos personales cuando corresponda.
- Definir las condiciones bajo las cuales se ejecutará la supresión y las situaciones en que pueda existir una obligación o fundamento legítimo para conservar determinados datos.
- Explicar cómo se tratarán las copias, los registros asociados y los sistemas relacionados, cuando corresponda.
- Evitar que la información eliminada siga utilizándose en procesos que ya no cuentan con una base válida para hacerlo.

Para todas las funcionalidades deberán implementar un mecanismo de verificación de identidad proporcional al riesgo, evitando recopilar información adicional innecesaria.



También deberán definir un flujo para gestionar las solicitudes que incluya, al menos, recepción, verificación, evaluación, ejecución o respuesta fundamentada, y cierre de la solicitud. Registren su estado y las fechas relevantes para poder hacer seguimiento.

Importante: el acceso, la rectificación y la supresión no deben implementarse como simples botones sin validaciones. Cada operación debe contar con controles de autorización, reglas de negocio y tratamiento seguro de los datos.

Para nuestro sistema, se creo un modulo especifico, que requiere hacer login para ingresar. Este modulo es paralelo al sistema principal, y se encarga de que el cliente pueda ejercer sus derechos como titular.



Parte 3. Implementación del registro de auditoría

Diseñen e implementen un mecanismo de auditoría que permita reconstruir las operaciones relevantes realizadas sobre los datos personales.

Deberán definir:

- Qué eventos se registrarán, por ejemplo, accesos a información sensible, modificaciones, exportaciones, supresiones, cambios de consentimiento y acciones administrativas.
- Qué atributos tendrá cada registro, como identificador del evento, fecha y hora, actor o cuenta involucrada, operación realizada, recurso afectado y resultado de la operación.
- Cómo se protegerán los registros contra modificaciones, accesos no autorizados y eliminación indebida.
- Quiénes podrán consultar los registros y con qué permisos.
- Durante cuánto tiempo se conservarán y cómo se eliminarán de forma segura cuando corresponda.

También deberán especificar explícitamente qué información no se registrará. Por ejemplo, no deberán almacenar contraseñas, tokens de autenticación, claves criptográficas ni el contenido completo de datos personales sensibles cuando no sea necesario para la finalidad de auditoría.

Cuando sea posible, utilice identificadores internos, referencias a registros o valores enmascarados en lugar de copiar directamente información personal en los logs.

Justifiquen las decisiones tomadas considerando el equilibrio entre trazabilidad, utilidad para la investigación de incidentes y minimización de datos.

Como evidencia, presentan el diseño del registro de auditoría y ejemplos de eventos generados durante operaciones reales de prueba.

Para la auditoría y trazabilidad implementaremos un sistema de Logs dividido en varios aspectos del sistema: transacción, evaluaciones financieras, inicio de sesion (login) y consentimiento.

Después de ejecutar una accion relacionada a estos, el resultado es un nuevo registro que guarda el actor (normalmente el Usuario), la fecha y hora en la que se realizo, el canal/dispositivo desde el cual se tomo la acción y otros detalles dependiendo de la accion.



Logs de transacciones:

Este log almacenará los movimientos transaccionales de los clientes, guardando datos útiles para realizar auditorías en caso de fraude u otro problema relacionado.

Campo	**Que se guarda**
Id Evento	Identificador numérico del log en sí
Fecha y hora	Momento exacto (computacionalmente) en el que se realizó la transacción
Id Usuario	Identificador del usuario que emite la transacción
Id Transaccion	Identificador propio de la transacción
Id Destinatario	Identificador del cliente que recibe la transacción
Banco Emisor	Institución financiera desde donde se emite el monto transferido
Banco Destinatario	Institución financiera que recibe el monto transferido
Monto	Cantidad monetaria que es emitida en la transacción
Canal	Medio por el cual se accedió al sistema y desde el cual se realizó la transferencia

Logs de evaluaciones financieras:

Este log almacenará las solicitudes de crédito, las aprobaciones de crédito, los rechazos de crédito, las evaluaciones de riesgo y demás actividades relacionadas.

Campo	**Que se guarda**
Id Evento	Identificador numérico del log en si

Fecha y hora	Momento exacto (computacionalmente) en el que se realizó la transacción
Id Usuario	Identificador del cliente que solicita alguna acción.
Id ejecutivo	Identificador de aquel que revisa y atiende la solicitud del ejecutivo. Esta opción puede tener el valor “No Aplica” en caso de que el tipo de operación corresponda
Tipo de operacion	Registra todos los eventos relacionados al motor de riesgo y la emisión crediticia
Canal	Medio por el cual se accedió al sistema y desde el cual se realizó la transferencia

Logs de inicio de sesión:

Campo	**Que se guarda**
Id Evento	Identificador numérico del log en si
Fecha y hora	Momento exacto (computacionalmente) en el que se realizó el inicio de sesión
Id Usuario	Identificador del cliente que solicita alguna acción.
Canal	Medio por el cual se accedió al sistema
Método de autenticación	Método por el cual se verificó la identidad del usuario que trataba de ingresar.

Logs de consentimiento:

Campo	**Que se guarda**
Id Evento	Identificador numérico del log en si
Fecha y hora	Momento exacto (computacionalmente) en el

	que se registró la acción
Id Usuario	Identificador del cliente que realizó la acción
Canal	Medio por el cual se accedió al sistema
Consentimiento	Indica el tipo de consentimiento al que se le está aplicando la acción
Accion	Indica la desicion tomada respecto

Información que no se registrará

En ninguno de los Logs se registrará información no concerniente a las actividades que se están realizando, no se almacenará ninguna contraseña, token o hash, la información personal identificable será registrada mediante identificadores o seudónimos.

Justificación de las decisiones

Se minimizó la mayor parte de la información personal o sensible registrada, pero no se pudo eliminar del todo, esto para mantener y respetar las legislaciones financieras del país, las cuales requieren que se conserve cierta trazabilidad reconstruible e identificable de los movimientos bancarios. La información que registramos servirá para hacer seguimiento e investigar incidentes cuando ocurran.

Seguridad de los registros

Para proteger los logs de modificaciones y eliminaciones indebidas,

Parte 4. Elaboración del plan de respuesta a incidentes de seguridad

A continuación nuestra organización muestra cómo maneja los incidentes de seguridad



A. Preparación

Responsables:

Cada rol tiene un suplente designado, para que ningún incidente dependa de una sola persona.

Se monitorea logs y sistemas de verificación de identidad y riesgos para emitir alertas automáticas al detectar comportamientos o situaciones anómalas

Recursos y procedimientos

- En los logs está bloqueado las acciones de UPDATE y DELETE para mantener la integridad.
- Respaldos cifrados, probados periódicamente y almacenados fuera del servidor principal.
- Se implementará la capacidad de invalidar y desconectar sesiones asoi como bloquear cuentas .

B. Detección y análisis

Criterios que usaremos para definir algo como amenaza o comportamiento potencialmente peligros

Indicador	Condicion

Intentos fallidos de login	3 intentos fallidos desactivará temporalmente la cuenta y enviará un mensaje de alerta al correo y teléfono del titular
Acceso sospechoso	Inicio de sesión desde otro dispositivo
Consulta de datos sospechoso	Ejecutivos accediendo a datos sin motivo alguno
Exposición o filtro de contraseñas	Contraseñas o tokens en repositorio, logs o reportes de terceros; credenciales de administrador en uso fuera de su ventana
Disponibilidad	Caída del servicio, errores masivos, base de datos inaccesible
Transacciones sospechosas	Montos o frecuencias fuera del patrón, destinatarios nuevos en cascada

Establecer cómo se evaluará el alcance, la gravedad y el posible impacto sobre los datos personales.

Diferenciar entre una alerta, un evento sospechoso y un incidente confirmado.

C. Contención

Acciones inmediatas:

- Revocar sesiones activas (invalidar JWT) de las cuentas afectadas.



- Restringir permisos o cuentas administradoras: suspender el rol o la cuenta interna involucrada (Operador, Auditor, Admin) y revisar accesos con motivo.
- Aislar componentes, por ejemplo sacando de línea el servicio, endpoint o servidor afectado.
- Suspender integraciones con terceros si el vector viene de ellos (bancos con brechas de seguridad por ejemplo).
- Si hay riesgo de fraude, congelar temporalmente transacciones sospechosas y avisar a los bancos asociados..

Preservación de evidencias

- Antes de apagar o reiniciar nada, tomar copia de los datos lo antes posible posible.
- Exportar los logs relevantes a un almacenamiento de solo lectura, con hash SHA-256 de cada archivo y registro de quién lo hizo (cadena de custodia).

D. Erradicación y recuperación

E. E

Erradicación

1. Identificar la causa raíz (credencial filtrada, inyección SQL, control de acceso roto, error de configuración, tercero comprometido).
2. Eliminar el vector: cerrar la vulnerabilidad, corregir el código y las validaciones, quitar accesos o cuentas maliciosas, eliminar persistencia.
3. Rotar secretos: contraseñas de servicio, claves de firma JWT, llaves de cifrado (nueva versión y re-cifrado de datos si estuvieron expuestas), claves de integraciones con terceros.
4. Forzar restablecimiento de contraseña en cuentas afectadas.
5. Revisar si el mismo defecto existe en otros módulos (consentimiento, portabilidad, créditos).

Recuperación

- Restaurar desde un respaldo previo al incidente, verificado como limpio, y reconciliar las transacciones ocurridas después.
- Validar la integridad de datos críticos: transacciones, saldos, créditos y scores contra la bitácora, y verificar la cadena de hashes.
- Reactivar cuentas por etapas, con vigilancia reforzada durante unos días.

F. E. Notificación y comunicación

- Titulares: Cuando se ven involucrados cualesquiera de sus datos dentro de la app, ya sean datos "sin importancia" o datos, personales, sensibles u obligaciones de carácter económico, financiero, bancario o comercial. Como Monify trata deuda, morosidad, créditos y transacciones, cualquier brecha con riesgo razonable sobre esos datos exige avisar a los titulares.
- Agencia de Protección de Datos Personales (Que pronto empezará a regir): el responsable debe reportar cualquier vulneración a las medidas de seguridad a la Agencia por los medios más formales y rápidos disponibles.

Cuando corresponda notificar, el contenido deberá contemplar:

Elemento	Que debe incluir
Descripción clara del incidente	Qué pasó, en lenguaje simple, sin tecnicismos innecesarios
Fecha y hora de detección	Detectado el (fecha y hora)

Tipos de datos afectados	Un listado y explicación de todos los datos que se vieron afectados
Motivos y razones	Explica el por que fueron vulnerados los datos. Ejemplos: fraude, suplantación, chantaje
Medidas de contención y mitigación	Las acciones tomadas para reducir el daño y proteger la integridad. Ejemplo; Sesiones desconectadas, cuenta bloqueada.
Recomendaciones	Medidas que el usuario puede tomar para protegerse. Ejemplo: Cambiar contraseña, desconfiar de llamados o mensajes que pidan datos, revisar movimientos.
Canal de contacto	Correos y formularios para atender las preguntas e inquietudes?

f. Lecciones aprendidas

- Documentar las causas del incidente.
- Identificar las medidas correctivas y preventivas.
- Proponer mejoras en los controles, procedimientos y mecanismos de detección.

El plan deberá indicar expresamente los responsables de cada fase, los criterios para escalar un incidente y las condiciones para cerrar el caso. Los plazos de notificación deben fundamentarse en la normativa aplicable al caso de estudio, sin asumir que existe un plazo universal para todos los incidentes.

Parte 5. Evidencias

- Como evidencia, presentan el modelo de datos del módulo, las pantallas o interfaces implementadas y pruebas que demuestren el registro, la consulta y la revocación del consentimiento.

Deberán justificar brevemente las decisiones de implementación, indicando por qué seleccionaron determinadas estructuras de datos, validaciones, controles de acceso y mecanismos de registro.

Además, deberán demostrar que los controles están integrados con los módulos existentes del proyecto y que no pueden eludirse mediante solicitudes directas al servidor o a la base de datos a través de interfaces no autorizadas.

No es suficiente presentar una propuesta teórica: las funcionalidades solicitadas deben estar implementadas en el código y contar con evidencias de funcionamiento. Si algún mecanismo depende de infraestructura externa que no se encuentra disponible, documenten la limitación y presenten una implementación de prueba que permita verificar la lógica correspondiente.

PARTE 5.1: Implementar estas partes dentro del codigo

El módulo deberá:

- Permitir consultar el historial de consentimientos y sus cambios de estado.
- Implementar un mecanismo para revocar el consentimiento y registrar la fecha y hora de la revocación.
- presentan el diseño del registro de auditoría y ejemplos de eventos generados durante operaciones reales de prueba.